



Факултет по Математика и Информатика
ПУ "Паисий Хилендарски"

МОНИТОРИНГ, КОНТРОЛ И ЗАЩИТА НА ПРИЛОЖНАТА И МРЕЖОВАТА ИНФРАСТРУКТУРА

Витали Атиас

Monitoring, Secure Configuration

До този момент курсът разглежда сигурността основно на ниво уеб приложение – authentication, сесии, JWT, XSS, SQL injection, HTTPS.

В тази лекция разширяваме перспективата.

Сигурността не приключва с писането на „сигурен код“.

Без наблюдение (monitoring), правилна конфигурация, защитена инфраструктура и контрол върху deployment процеса, системата остава уязвима.

Logging & Monitoring – защо сигурността без наблюдение е непълна

До момента говорихме как да предотвратим атаки.

Но трябва да приемем нещо фундаментално:

В реална среда атаките се случват.

Въпросът не е „дали“, а „кога“.

Ако системата няма механизъм да засече подозрително поведение, тя е сляпа.

Security Logs

Security логовете са записи за събития, свързани със сигурността.

Примери за важни събития:

- Неуспешни login опити
- Успешен login от нов IP
- Смяна на парола
- Достъп до администраторски ресурс
- Промяна на роля (user → admin)

Ако нямаме логове не можем да разследваме инцидент, не можем да докажем злоупотреба и не знаем какво се е случило

Audit Trails

Audit trail означава пълна проследимост на действията.

Пример:

Timestamp	User	Action	Resource
10:10	admin	DELETE	user:124
10:12	admin	CREATE	user:200

Audit trail е критичен за:

- Финансови системи
- Здравни системи
- Административни системи

Без audit trail няма accountability.

Secrets Management

Никога не трябва да има:

`db_password=admin123`

в git repository.

Secrets трябва да се съхраняват в:

- environment variables
- secret vault системи

Пример:

HashiCorp Vault

Достъпен .env

Често срещан проблем:

<https://example.com/.env>

Ако файлът е публично достъпен, изтичат:

- DB пароли
- API ключове
- JWT secrets

Docker

Типични проблеми:

- Контейнерът работи като root
- Отворени ненужни портове
- Hardcoded credentials

Secure Configuration – Общ риск

Неправилна или небезопасна конфигурация на приложението и инфраструктурата може директно да доведе до компрометиране на системата, дори без сложна атака.

Това включва:

- Използване на default credentials (напр. admin/admin)
- Активиран debug mode в production
- Включен directory listing
- Неправилно конфигуриран CORS

Общият проблем:

Системата е функционална, но не е конфигурирана сигурно, което отваря директни вектори за атака.